

看板驅動的 Agentic Loop： 金融級安全 AI Agent 研發新範式

以「唯讀憲法」構築跨團隊安全護欄，打造人控方向、AI 奔跑的自動化閉環

移卡即交付：看板操作觸發 Agentic Loop 閉環運轉。在金融合規護欄下，人只出手三次——提需求、批規格、按合併——其餘交給 AI。

01 情境 — 一個動作，啟動整個開發迴圈

PM 在看板工具 (Taiga / Jira / Azure Boards...) 把需求卡片從「Backlog」拖進「Spec Drafting」，AI agent 立刻讀取卡片上的需求描述，把可測試的規格草稿寫回卡片；工程師在「Spec Review」直接於卡片上確認或修改規格，把卡片拖進「Dev」的那一刻就是核准——Agentic Loop 隨即接手：寫程式、跑測試、對照安全規則，最後產出一個已審查、合規的 PR，等候人工確認合併。

整個跨職能團隊——PM、工程師——都以最自然的看板動作驅動 AI 開發迴圈，不需手動啟動任何腳本。規格不對可以退回重生、需求不對可以退回 PM、迴圈失敗會自動升級人工——每一條路都在看板上。

02 痛點 — 放手自動迭代的三個風險

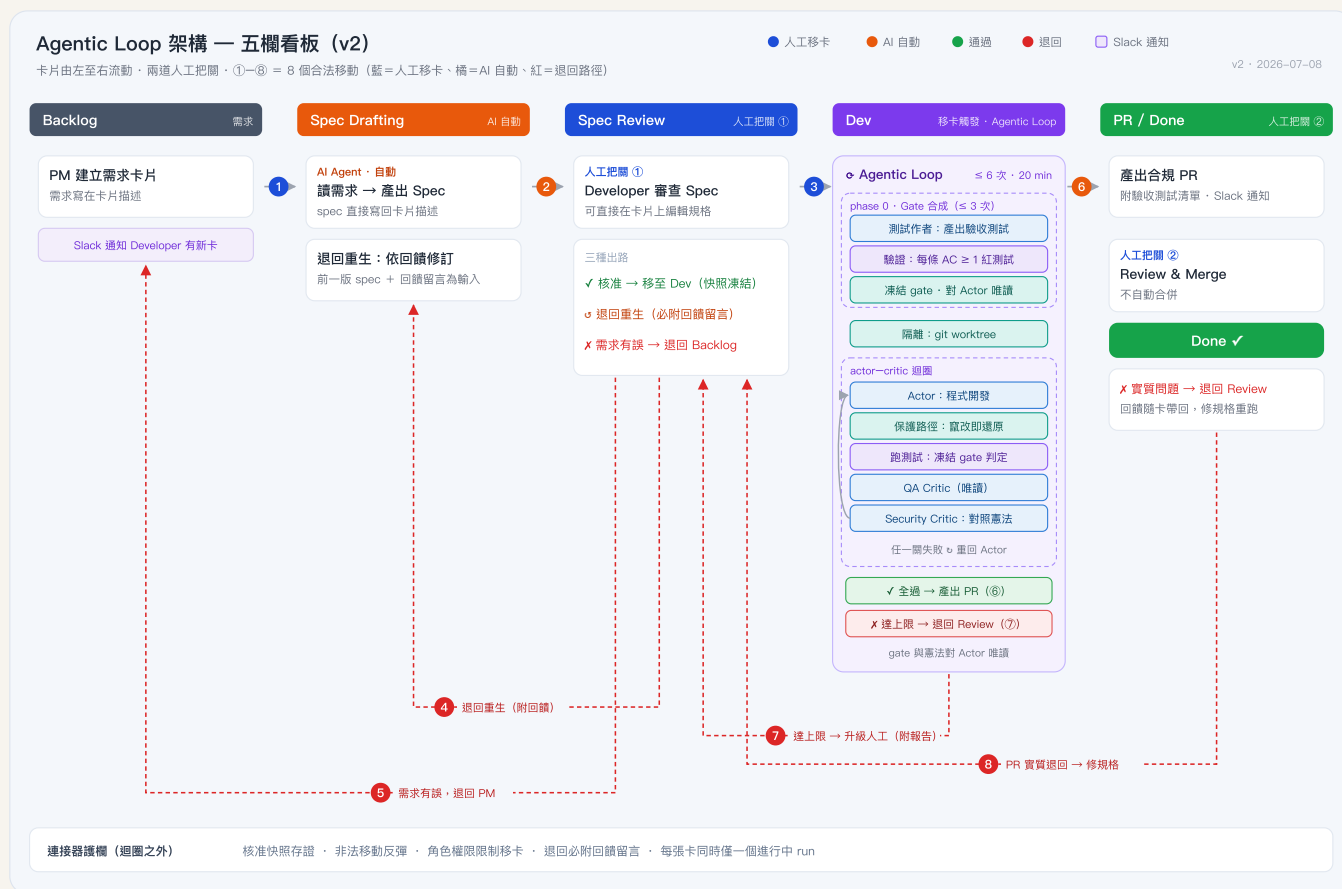
時間 時間黑洞。就算規格寫得再好，每一輪「跑測試 → 看錯誤 → 修改 → 再複查」仍要工程師手動進行——這才是真正吞掉時間的地方。

安全 安全風險。在銀行裡若放手讓 AI 無限制自跑很危險——它可能為了讓測試通過而偷偷改掉測試 (reward hacking, 鑽漏洞取巧)，或在不知不覺中違反某條安全規則。

流程 流程斷點。agent 迴圈與日常敏捷流程脫節——團隊各自在看板推卡片，卻要另外手動啟動 agent，造成斷點，也讓非工程師角色難以參與。

03 解法 — 看板為介面，一個受控的 Actor ↔ Critic 迴圈

我們的主張很簡單：價值不在模型多聰明，而在模型之外那一圈銀行可稽核的確定性控制碼——看板是唯一介面，連接器強制執行狀態機，AI 只在護欄裡奔跑。



看板五欄 (Backlog → Spec Drafting → Spec Review → Dev → PR/Done) 由左至右流動，①—⑧ 共 8 個合法移動：移卡即觸發、退回即回饋。規格審查有三種出路——核准（移卡當下快照凍結）、退回重生（必附回饋）、退回需求（交還 PM）；迴圈達上限的升級（⑦）與 PR 實質退回（⑧）也都回到規格這一關，確保「規格永遠是程式碼存在的理由」。

①

受控封閉迴圈

Actor ↔ Critic 最多執行 6 次、共用 20 分鐘上限，收斂即停、達上限即安全升級；驗收測試與憲法對 Actor 唯讀、不可竄改，竄改即被偵測並還原。

②

兩道人工把關

規格核准 = 把卡片移進 Dev，當下快照存證；不合意可直接修改後核准、退回重生或退回需求。合併前一定人工 Review & Merge，不自動合併。

③

可維護的憲法

版本控管的規則集 (spec-driven)，新增一條即套用至後續所有變更，跨團隊可沿用。

工具 Codex CLI 擔任 Actor (沙箱寫入) + 唯讀 Critic agents (QA / Security) + Connector 串接看板工具、測試與 Git——所有安全關卡都在我們自己的程式碼裡，不在模型裡。

連接器護欄 (迴圈之外): 核准快照存證 · 非法移動反彈 · 角色權限限制移卡 · 退回必附回饋留言 · 每張卡同時僅一個進行中 run

04 預期效益

自動運轉	把手動的「寫 → 測 → 修 → 複查」變成能自動運轉的 agent 迴圈，直接產出一個已審查、合規、通過安全檢核的 PR。
安全實證	迴圈紀律不是簡報主張，而是已可運行的原型：竄改測試被即時偵測並還原、失敗後自我修正收斂、矛盾規格在上限處安全停止——三個情境皆可現場演示，並附離線測試套件。
可擴散	可重用的迴圈樣板、連接器護欄與版本控管的憲法——新團隊帶著自己的看板即可套用，擴散到集團所有開發團隊。

05 評分對應

評分面向	本方案的對應證據
可行性	可運行原型 + 離線測試套件；防 reward hacking（測試 / 憲法唯讀 + git diff 偵測還原）；迭代與時間上限；不自動合併。
AI 工具應用	Spec / Actor / QA / Security 多 agent 分工；確定性測試先把關、LLM 評審在後，避免模型自我認證。
業務價值	整段手動迭代自動化；規格即核准紀錄（快照存證，可稽核）；憲法一改、全隊生效。
創新	看板即介面——移卡即觸發、退回即回饋，非工程師也能驅動；phase 0 自產驗收 Gate，先凍結靶再開發。

06 Demo 規劃 — 三幕現場演示

Act 1 一次就過 把卡片移進 Dev，迴圈第一輪收斂，產出合規 PR。	Act 2 自我修正 刻意核准一份含糊規格——看它先失敗、讀回饋、下一輪修好。	Act 3 知所進退 矛盾規格永不收斂——達上限安全停止，附失敗報告退回 Spec Review。
--	--	--

3 句話總結

- 1 在看板移一張卡，AI 就自動完成規格、開發、測試與安全複查，產出合規 PR——但在銀行裡直接放手讓 AI 無限制自跑很危險：它可能取巧改掉測試，或悄悄違反安全規則。
- 2 我們交付的是「受控迴圈」：看板五欄、8 個合法移動，規格與合併兩端保留人工把關，驗收測試與憲法對 Actor 唯讀、迭代設上限——規格錯了可退回重生、失敗會安全升級，每一條路都在看板上完成。
- 3 這套迴圈已是可運行、可演示的原型；「安全的 agent 迴圈」與「可維護的憲法」是可擴散的樣板，集團各團隊帶著自己的看板即可沿用。